COMPTIA SECURITY+ SY0-701 DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · DNS Attacks

Mestre CyberSec · **Aula 2.4 — DNS Attacks** (8:57) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: DNS (o listado telefônico da rede): DNS spoofing/cache poisoning (resposta FALSA guardada em cache do resolver); Domain hijacking (rouba domínio no registrador); URL hijacking/typosquatting (registrar 'goggle.com'); DNS tunneling (esconde dado nas consultas DNS — exfiltra). Defes

💡 Highlights que a prova CompTIA cobra

- DNS spoofing/cache poisoning: resposta FALSA guardada em cache
- Typosquatting: registra domínio com typo (rn/m, 0/o) — phishing
- DNS tunneling: exfiltra dado escondido em queries DNS

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning
- 'registers domain similar to legitimate one' = typosquatting

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — DNS Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Sistema de Nomes de Domínio (DNS)

Sistema de nomes hierárquico que traduz nomes de domínio legíveis por humanos (ex.: exemplo.com) em endereços IP. Funciona como a 'lista telefônica da internet' e é alvo frequente de ataques, pois comprometê-lo redireciona usuários de forma transparente.

⚠ ***Armadilha CompTIA:*** *Any question involving name-to-IP resolution, resolvers, or authoritative servers — DNS is the underlying protocol being attacked.*

• Falsificação de DNS / Envenenamento de Cache (N/A)

Ataque em que uma resposta DNS forjada é injetada no cache de um resolver, fazendo com que consultas legítimas futuras retornem o IP do atacante. As vítimas são redirecionadas silenciosamente para servidores maliciosos sem consultar o servidor autoritativo real.

⚠ ***Armadilha CompTIA:*** *Trigger phrase: 'fake DNS response directs user to attacker server' = DNS spoofing/cache poisoning. Distinguish from DNS amplification (a DoS attack on availability, not redirection).*

• Sequestro de Domínio (N/A)

Tomada não autorizada do registro de um nome de domínio, geralmente pelo roubo de credenciais do registrador, exploração de vulnerabilidades do registrador ou manipulação de registros DNS no nível do registrador. O atacante controla o domínio inteiro, não apenas respostas em cache.

⚠ ***Armadilha CompTIA:*** *Look for wording like 'attacker changes nameservers at the registrar' or 'stolen registrar account' — that is domain hijacking, not cache poisoning (which is local to a resolver).*

• Typosquatting (Sequestro por Erro de Digitação) (N/A)

Registro de um nome de domínio que é uma variação/comum erro de digitação de um site legítimo (ex.: 'gogle.com', 'paypa1.com') para capturar usuários que erram a URL. Frequentemente usado para phishing, distribuição de malware ou receita de anúncios.

⚠ ***Armadilha CompTIA:*** *Trigger phrase: 'registers a domain similar to a legitimate one' = typosquatting. Watch for character substitution patterns: rn↔m, 0↔o, 1↔l, adding/removing letters.*

• Tunelamento DNS (N/A)

Técnica que codifica dados de outro protocolo ou aplicação dentro de consultas e respostas DNS para burlar controles de rede. Atacantes a usam principalmente para exfiltração de dados ou comunicação de comando e controle (C2), pois o tráfego DNS raramente é inspecionado.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'data hidden inside DNS queries' or 'exfiltration over port 53' = DNS tunneling. Look for unusually long TXT records or high volumes of DNS queries to a single domain.*

• Extensões de Segurança do DNS (DNSSEC)

Conjunto de extensões do DNS que fornece autenticação de origem e integridade por meio de assinaturas digitais (usando registros DNSKEY e RRSIG). Impede envenenamento de cache e falsificação, validando criptograficamente que as respostas vêm do servidor autoritativo.

⚠️ ***Armadilha CompTIA:*** *If a question asks 'how do you PREVENT DNS spoofing?' the answer is DNSSEC — do not confuse with DNS tunneling (an attack) or TLS/HTTPS (which encrypts but does not authenticate DNS responses).*

• Resolvedor DNS (Resolvedor Recursivo) (N/A)

Servidor que realiza consultas recursivas em nome dos clientes, consultando servidores raiz, TLD e autoritativos, e então armazenando o resultado em cache. O envenenamento de cache visa o cache do resolvedor para afetar todos os usuários que o consultam.

⚠️ ***Armadilha CompTIA:*** *When a scenario mentions 'attacker poisons the cache of a DNS server used by many users,' the targeted component is the recursive resolver — not the authoritative server or the client.*

• Sequestro de Subdomínio / DNS Pendente (N/A)

Ataque em que um registro DNS (geralmente um CNAME) aponta para um serviço externo (ex.: provedor de nuvem) que foi desprovisionado, permitindo que um atacante reivindique esse recurso e sirva conteúdo sob o domínio legítimo.

⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'DNS record still points to a service that no longer exists' = dangling DNS / subdomain takeover. Note that this exploits misconfiguration, not a DNS protocol flaw.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Funcionários de uma cooperativa de crédito relatam que, ao acessar o portal bancário público pela rede corporativa, são direcionados a uma página de login falsa muito parecida com a original. A equipe de segurança verifica que os registros do portal nos nameservers autoritativos estão corretos, o servidor web nunca foi comprometido e usuários em outras redes chegam ao site legítimo. Muitas estações de trabalho usam um resolvedor recursivo compartilhado upstream. Qual é a causa MAIS provável do redirecionamento?

A) Sequestro de domínio no registrador

B) Takeover de subdomínio de um registro CNAME órfão

C) Respostas DNS falsificadas aceitas no cache do resolvedor recursivo

D) Typosquatting do endereço web do portal

QUESTÃO 2 · CENÁRIO DE EXAME

Na segunda-feira de manhã, os funcionários descobrem que o site público da empresa e o e-mail corporativo estão inacessíveis. A investigação mostra que o e-mail de contato da conta do registrador recebeu solicitações de redefinição de senha de uma campanha de phishing dois dias antes, e o WHOIS público agora lista dados de titularidade diferentes e nameservers apontando para infraestrutura desconhecida. Os servidores web e de e-mail internos nunca foram acessados. Qual ataque DESCREVE MELHOR o ocorrido?

A) Sequestro de domínio via conta de registrador comprometida

B) Envenenamento de cache DNS do resolvedor interno da empresa

C) DNS tunneling com consultas de comando e controle

D) Takeover de subdomínio do registro MX

QUESTÃO 3 · CENÁRIO DE EXAME

A equipe de suporte de um fornecedor de software recebe reclamações de clientes que, após digitar errado a URL de download do produto (invertendo duas letras), caíram em uma página idêntica que entregava um executável malicioso de 'atualização'. A inteligência de ameaças descobre que o domínio parecido foi registrado anonimamente logo após o lançamento do produto, e nada na infraestrutura de DNS ou web do próprio fornecedor foi alterado. Qual ataque está ilustrado?

A) Envenenamento de cache DNS

B) Typosquatting (URL hijacking)

C) Sequestro de domínio

D) Takeover de subdomínio

QUESTÃO 4 · CENÁRIO DE EXAME

Uma revisão de DLP mostra que nenhum anexo de e-mail ou upload para nuvem sai da rede, mas os logs do firewall revelam uma estação de trabalho enviando milhares de consultas de registros TXT a uma única zona autoritativa externa, cada consulta carregando uma longa string codificada em base32 sob um subdomínio único e recebendo grandes respostas TXT. O volume diário de DNS para essa zona excede 1 GB. Qual é a atividade MAIS provável?

A) Um ataque DDoS de amplificação DNS refletido pela rede

B) Uma transferência de zona (AXFR) acidentalmente mal configurada

C) Uma falha de validação DNSSEC gerando respostas gigantes

D) DNS tunneling usado para exfiltrar dados e manter comando e controle

QUESTÃO 5 · CENÁRIO DE EXAME

Após um incidente em que um resolvedor recursivo aceitou respostas falsificadas que direcionavam clientes ao servidor do atacante, o diretor de segurança quer um mecanismo que permita aos resolvedores verificar criptograficamente que as respostas para a zona pública da organização são autênticas e não modificadas antes de usá-las. Qual controle deve ser implementado?

A) Reduzir o TTL de todos os registros DNS públicos

B) Assinar digitalmente a zona pública usando DNSSEC

C) Configurar um registro curinga cobrindo todos os subdomínios

D) Habilitar recursão aberta no resolvedor voltado ao público

QUESTÃO 6 · CENÁRIO DE EXAME

A equipe de engenharia de nuvem desativou um microssite de marketing hospedado em um serviço de hospedagem estática de terceiros, mas esqueceu de remover o registro CNAME que apontava para ele. Semanas depois, clientes relatam ver conteúdo controlado pelo atacante, incluindo JavaScript malicioso, servido naquele subdomínio; um scan externo confirma que o endpoint de hospedagem agora pode ser reivindicado por qualquer novo inquilino. O que MELHOR descreve a fraqueza explorada?

A) Uma transferência de zona expôs toda a zona ao atacante

B) O cache do resolvedor recursivo foi envenenado

C) Um registro DNS órfão (dangling) permitindo takeover de subdomínio

D) O bloqueio de transferência do registrador estava desativado

QUESTÃO 7 · CENÁRIO DE EXAME

Depois de confirmar que um malware exfiltrou um banco de dados de clientes por meio de consultas DNS enviadas diretamente a servidores autoritativos externos, a equipe de segurança precisa redesenhar o DNS de saída da rede. Qual abordagem previne MAIS eficazmente que os endpoints façam tunneling de dados por meio de consultas DNS?

A) Permitir saída DNS (porta 53 e DoT na 853) somente para resolvedores recursivos internos designados, bloquear DNS externo direto e monitorar o volume de consultas e tipos de registro

B) Instruir todos os clientes a usar TTLs menores para limitar entradas envenenadas em cache

C) Habilitar recursão para clientes externos não confiáveis no servidor autoritativo público

D) Converter todos os registros TXT legados em registros curinga para reduzir a variedade de consultas

QUESTÃO 8 · CENÁRIO DE EXAME

Convidados no Wi-Fi da sala de conferências são redirecionados a uma página de phishing ao visitar o portal de benefícios corporativo, enquanto usuários cabeados no escritório principal não são afetados. A captura de pacotes na VLAN de convidados mostra respostas DNS chegando do endereço MAC de um notebook desconhecido milissegundos antes de o gateway resolutor legítimo responder, mapeando o portal para um endereço IP estrangeiro. Nenhum registro no registrador ou autoritativo foi alterado, e o cache do resolvedor corporativo está limpo. Qual ataque MELHOR corresponde às observações?

A) Envenenamento de cache do nameserver autoritativo da organização

B) Sequestro de domínio por credenciais roubadas do registrador

C) DNS tunneling por meio de registros TXT

D) DNS spoofing por um atacante on-path na rede de convidados

QUESTÃO 9 · CENÁRIO DE EXAME

Uma startup de fintech está se preparando para seu lançamento público, e seu modelo de ameaças identifica atacantes registrando versões escritas incorretamente do domínio da marca para aplicar phishing nos primeiros clientes. Qual medida proativa REDUZ MELHOR esse risco de typosquatting para a marca?

A) Publicar assinaturas DNSSEC para a própria zona da empresa

B) Registrar erros comuns de digitação, transposições de letras e TLDs alternativos da marca

C) Exigir que todos os navegadores dos clientes resolvam por meio de DNS-over-HTTPS

D) Reduzir o TTL dos registros A e CNAME da marca

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa se recuperou de um incidente em que um atacante usou credenciais roubadas do registrador para alterar os nameservers do domínio, levando dias para retomar o controle. O CISO quer controles voltados especificamente a evitar uma recorrência no nível do registrador. Qual combinação TRATA MELHOR esse risco?

A) Implantar assinatura DNSSEC e split DNS nas zonas internas

B) Habilitar um registro curinga e reduzir os TTLs de todos os registros

C) Habilitar o bloqueio de transferência no registrador, exigir MFA na conta do registrador e monitorar alterações não autorizadas de WHOIS ou nameservers

D) Migrar a hospedagem DNS para um resolvedor recursivo aberto que aceite atualizações dinâmicas permissivas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Respostas DNS falsificadas aceitas no cache do resolvedor recursivo

Como os dados da zona autoritativa estão corretos e o problema afeta apenas usuários que dependem do resolvedor recursivo compartilhado, o resolvedor deve ter aceitado uma resposta falsificada e a armazenou (DNS spoofing/cache poisoning). Até a entrada envenenada expirar ou o cache ser limpo, os clientes são enviados silenciosamente ao IP do atacante. O sequestro de domínio afetaria todos os usuários mundialmente, pois altera registros no nível do registrador; o typosquatting exige que os usuários digitem o endereço errado; o takeover de subdomínio envolve um registro órfão apontando para um recurso de terceiros reivindicável, o que não é o caso aqui.

Questão 2: Alternativa A — Sequestro de domínio via conta de registrador comprometida

O atacante obteve credenciais do registrador e modificou as informações de titularidade e os nameservers, redirecionando o tráfego do domínio e os registros MX para infraestrutura controlada pelo atacante. Isso é um sequestro de domínio clássico. O envenenamento de cache afeta apenas caches de resolvedores, não a titularidade autoritativa; o DNS tunneling esconde dados dentro de consultas para exfiltração ou C2 e não altera o WHOIS; o takeover de subdomínio exige um registro órfão apontando para um serviço reivindicável e não tomaria o domínio inteiro, incluindo o MX.

Questão 3: Alternativa B — Typosquatting (URL hijacking)

Registrar uma variante escrita incorretamente de um domínio legítimo para capturar tráfego de erros de digitação e se passar pela marca é typosquatting, também chamado de URL hijacking. Como a infraestrutura do fornecedor não foi tocada, o envenenamento de cache (uma resposta falsificada armazenada no cache de um resolvedor) e o sequestro de domínio (roubo do domínio no nível do registrador) não se aplicam. O takeover de subdomínio exige um registro órfão na própria zona da vítima, ausente aqui.

Questão 4: Alternativa D — DNS tunneling usado para exfiltrar dados e manter comando e controle

Codificar dados em subdomínios únicos e carregar respostas em registros TXT (ou NULL) é a assinatura do DNS tunneling, técnica usada por atacantes para exfiltrar dados e manter canais de C2, já que o DNS raramente é bloqueado. A amplificação mostraria a rede sendo usada para inundar um terceiro com consultas de fonte falsificada, e não pares estruturados de consulta/resposta; a transferência de zona é uma operação TCP única entre servidores, não consultas repetidas a subdomínios; falhas de validação DNSSEC produzem status SERVFAIL ou bogus, e não megabytes de tráfego coordenado.

Questão 5: Alternativa B — Assinar digitalmente a zona pública usando DNSSEC

O DNSSEC adiciona assinaturas digitais (registros RRSIG/DNSKEY) e uma cadeia de confiança da raiz até a zona, permitindo que resolvedores validadores detectem respostas falsificadas ou adulteradas e as rejeitem — a defesa criptográfica direta contra cache poisoning. TTLs menores apenas reducem quanto tempo uma entrada envenenada persiste; registros curinga não têm função de integridade; recursão aberta aumenta a exposição (incluindo abuso para amplificação DDoS) e não valida respostas.

Questão 6: Alternativa C — Um registro DNS órfão (dangling) permitindo takeover de subdomínio

Quando um registro DNS (geralmente um CNAME) aponta para um recurso de terceiros que foi desprovisionado mas não reivindicado, um atacante pode registrar esse recurso no provedor e servir conteúdo sob o subdomínio da vítima — um takeover de subdomínio que explora um registro órfão (dangling). Isso permite phishing, roubo de cookies ou contornar expectativas de mesma origem sob um hostname confiável. A transferência de zona vazaria dados de registros, mas não serviria conteúdo hostil; o cache poisoning é estado transitório no cache de um resolvedor; o bloqueio de transferência se relaciona ao sequestro de domínio no nível do registrador.

Questão 7: Alternativa A — Permitir saída DNS (porta 53 e DoT na 853) somente para resolvedores recursivos internos designados, bloquear DNS externo direto e monitorar o volume de consultas e tipos de registro

Obrigar cada endpoint a resolver por meio de resolvedores internos controlados (bloqueando acesso direto às portas 53/853 na internet) cria um ponto de controle onde a equipe pode registrar, inspecionar e limitar consultas, além de alertar sobre marcas do tunneling — uso intenso de registros TXT/NULL, rótulos longos codificados e alto volume de consultas para uma única zona. TTLs menores não afetam o tunneling; habilitar recursão aberta em um servidor autoritativo convida ao abuso de amplificação; registros curinga não restringem o que um atacante pode consultar.

Questão 8: Alternativa D — DNS spoofing por um atacante on-path na rede de convidados

Uma resposta DNS falsificada correndo à frente da resposta legítima vinda de um MAC inesperado no mesmo segmento local é a marca de um atacante on-path (frequentemente usando ARP spoofing) realizando DNS spoofing em tempo real. Como os dados autoritativos e os caches não foram tocados, as opções que envolvem caches envenenados ou

alterações no registrador não se encaixam, e nada na captura mostra dados contrabandeados dentro de consultas como no DNS tunneling.

Questão 9: Alternativa B — Registrar erros comuns de digitação, transposições de letras e TLDs alternativos da marca

O registro defensivo de prováveis variantes de erros de digitação (letras transpostas, singular/plural, TLDs alternativos) remove do mercado os nomes semelhantes mais atrativos antes que atacantes possam reivindicá-los — a contramedida padrão contra o typosquatting. O DNSSEC protege a integridade da própria zona da empresa, mas não afeta registros de terceiros; o DNS-over-HTTPS afeta o transporte das consultas, não quais domínios existem; valores de TTL são irrelevantes para a disponibilidade de domínios.

Questão 10: Alternativa C — Habilitar o bloqueio de transferência no registrador, exigir MFA na conta do registrador e monitorar alterações não autorizadas de WHOIS ou nameservers

A conta do registrador foi o vetor de ataque, então os controles devem ficar lá: um bloqueio de transferência/registro impede alterações não autorizadas de nameservers ou titularidade, a MFA derrota o roubo de credenciais mesmo que a senha seja phished, e o monitoramento de alterações de WHOIS/nameservers oferece aviso precoce para que o domínio possa ser recuperado rapidamente. DNSSEC e split DNS protegem a integridade das respostas e o nomespace interno, não o acesso ao registrador; registros curinga e TTLs não têm relação com sequestro; recursão aberta com atualizações dinâmicas permissivas na verdade expandiria a superfície de ataque.